

CHECKLIST · PYMES

Checklist de ciberhigiene

32 controles esenciales para pymes, organizados según las funciones del **NIST CSF 2.0** y mapeados al grupo de implementación 1 de los **CIS Controls (IG1)**. Marca cada control como hecho, en curso o pendiente. Si no puedes marcar la mayoría de Proteger y Recuperar, empieza por ahí.

Gobernar (GV)

☐

Hay un responsable de seguridad designado (interno o externo, aunque sea a tiempo parcial). [CIS 14]

☐

Existe un inventario de proveedores tecnológicos críticos con sus contactos. [CIS 15]

☐

Se ha definido qué datos son críticos y dónde se almacenan. [CIS 3]

Identificar (ID)

☐

Inventario actualizado de dispositivos (portátiles, móviles, servidores). [CIS 1]

☐

Inventario de software autorizado; se elimina el no autorizado. [CIS 2]

☐

Inventario de cuentas de usuario y de servicio, con responsable de cada una. [CIS 5]

☐

Listado de cuentas con privilegios de administrador, revisado periódicamente. [CIS 5]

Proteger (PR)

☐

MFA activado en correo, VPN y todos los accesos administrativos. [CIS 6]

☐

Contraseñas únicas y gestor de contraseñas corporativo en uso. [CIS 5]

☐

Principio de mínimo privilegio; se revisan accesos en altas y bajas. [CIS 6]

☐

Cifrado de disco activado en portátiles y móviles. [CIS 3]

☐

Copias de seguridad automáticas y cifradas siguiendo la regla 3-2-1. [CIS 11]

☐

Actualizaciones automáticas de sistema operativo y aplicaciones. [CIS 7]

☐

Antivirus/EDR gestionado y activo en todos los equipos. [CIS 10]

☐

SPF, DKIM y DMARC configurados en el dominio de correo. [CIS 9]

☐

Filtro antimalware y antispam activo en el correo. [CIS 9]

☐

Bloqueo de macros de Office no firmadas. [CIS 9]

☐

Wi-Fi corporativo separado del de invitados; cifrado WPA2/WPA3. [CIS 12]

☐

Cortafuegos perimetral y de equipo activados. [CIS 13]

☐

Microsoft 365 / Google Workspace con configuración segura y sin reenvío externo abierto. [CIS 4]

Detectar (DE)

☐	Registros (logs) de acceso a correo e identidad activados y conservados. [CIS 8]
☐	Alertas de inicio de sesión sospechoso o imposible configuradas. [CIS 8]
☐	Revisión periódica de reglas de reenvío y delegaciones del correo. [CIS 9]

Responder (RS)

☐	Existe un plan de respuesta a incidentes escrito y accesible. [CIS 17]
☐	Roles y contactos de crisis definidos (equipo interno y soporte externo). [CIS 17]
☐	Procedimiento para notificar incidentes (incluida la AEPD si hay datos personales). [CIS 17]
☐	Se han realizado simulacros de phishing en los últimos 12 meses. [CIS 14]
☐	Formación de concienciación a empleados al menos una vez al año. [CIS 14]

Recuperar (RC)

☐	Las copias de seguridad se han restaurado y probado en los últimos 6 meses. [CIS 11]
☐	Existe un plan de continuidad para los sistemas críticos. [CIS 11]
☐	Contactos de soporte/proveedor disponibles fuera del horario laboral. [CIS 17]
☐	Procedimiento de comunicación a clientes en caso de brecha. [CIS 17]

¿Te quedan muchas casillas sin marcar? El diagnóstico Q-Start de Qerub las convierte en un plan priorizado de 90 días. Escríbenos a info@qerub.com.